Octobre 2026

Rapport de TP

Investigation d'incident (SOC L1)

Pape Aldiouma SARR
L3 Cybersecurite - Module : Ethical Hacking / SOC

Rapport de travaux pratiques : TP 5, Investigation d'incident SOC L1. Parcours SaaS : triage, investigation, IOC, correlation, timeline, MITRE ATT&CK, Case Elastic Security et rapport d'incident.



Republique du Senegal, Un Peuple, Un But, Une Foi
Ministere de l'Enseignement Superieur, de la Recherche et de l'Innovation
Direction Generale de l'Enseignement Superieur Prive
Institut Superieur de Management
Annee academique 2026-2027

Table des matieres

Partie I : Presentation et methodologie de navigation....3
Partie II : Etape 0 - Preparer l'incident....5
Partie III : Etape 1 - Detection initiale....6
Partie IV : Etape 2 - Triage....8
Partie V : Etape 3 - Investigation (5W)....10
Partie VI : Etape 4 - Tableau IOC....13
Partie VII : Etape 5 - Correlation....15
Partie VIII : Etape 6 - Timeline de l'incident....19
Partie IX : Etape 7 - MITRE ATT&CK....21
Partie X : Etape 8 - Case Elastic Security....22
Partie XI : Rapport d'incident officiel (13 sections)....27
Conclusion generale....31

Partie I : Présentation du travail

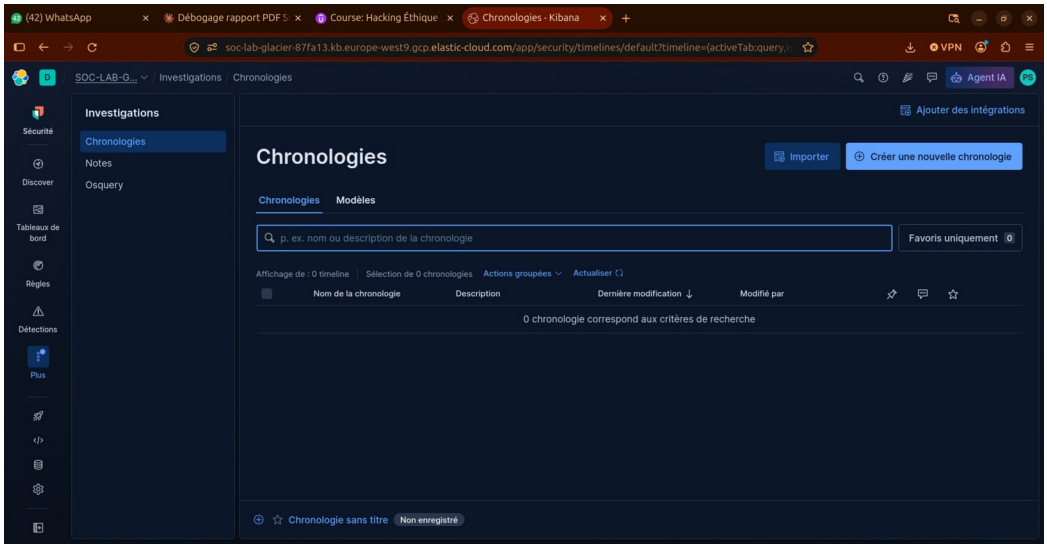
Ce rapport documente la réalisation complète du TP5 - SOC L1 : Investigation d'incident, cinquieme et dernier volet du fil rouge SaaS sur Elastic Cloud Hosted (déploiement SOC-LAB-GLACIER, GCP Paris europe-west9). L'objectif est de mener une investigation complète sur un incident simule : triage, recherche et correlation d'événements, identification d'IOC, reconstruction d'une timeline, cartographie MITRE ATT&CK, ouverture d'un Case Elastic Security et rédaction d'un rapport d'incident.

Chaque étape ci-dessous précise, dans l'ordre exact suivi pendant le TP : comment réaliser l'action (chemin de menu Kibana précis), pourquoi elle est nécessaire, et ce qu'elle apporte au rapport final. Le but est qu'une personne qui n'a jamais fait ce TP puisse suivre ce document a la lettre et refaire exactement le même parcours.

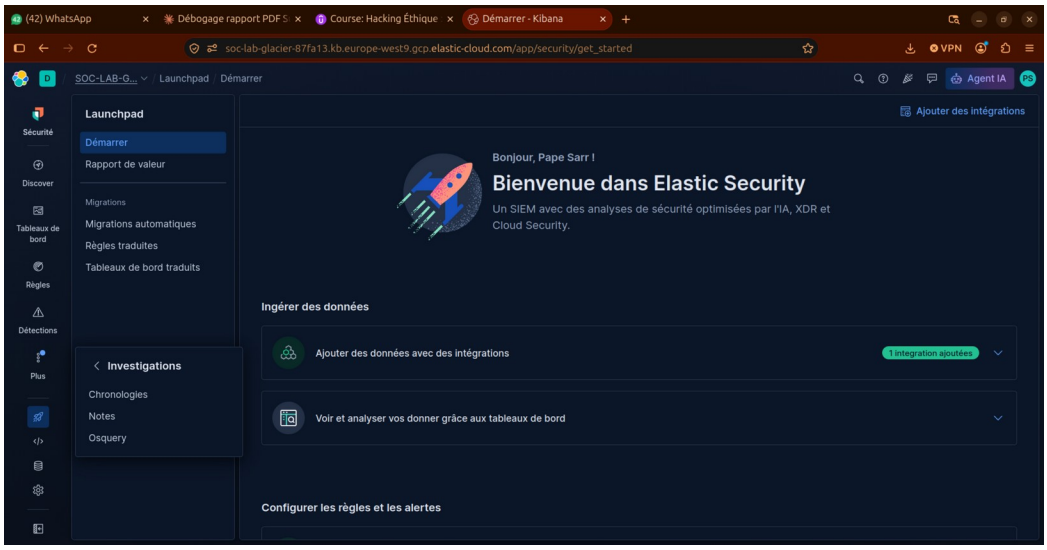
Navigation générale dans Kibana Security

Rappel des points d'entrée utilises tout au long de ce TP (menu de gauche de l'interface Kibana) :

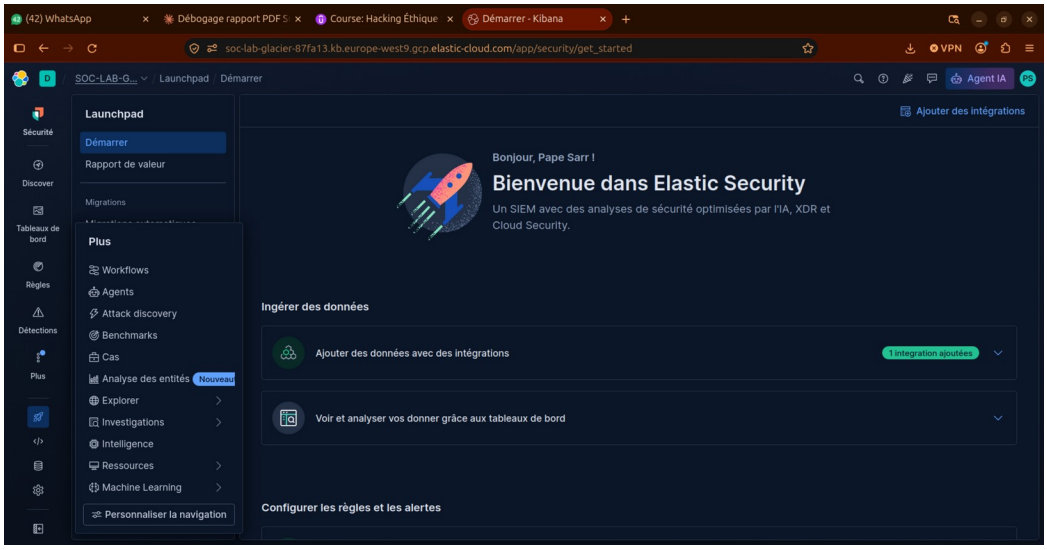
- Discover : icone boussole dans le menu de gauche - recherche libre d'événements bruts (KQL) sur une Data View.
- Detections > Alertes : icone triangle d'alerte - vue dédiée aux alertes générées par les règles de détection (SOC-LAB-*).
- Plus > Investigations > Chronologies : les Timelines Kibana, pour construire une chronologie d'investigation et epingler des documents clés.
- Icone </> (barre laterale gauche, sous l'icone fusee) : Dev Tools, console pour exécuter des requêtes EQL/DSL brutes.
- Plus > Cas : la gestion des Cases Elastic Security (dossier d'incident officiel, pieces jointes, commentaires).



Accès aux Timelines : menu de gauche > Plus > Investigations > Chronologies.



Sous-menu Investigations deroule depuis le bouton Plus : Chronologies, Notes, Osquery.



Le bouton Plus (en bas du menu de gauche) regroupe les fonctionnalités secondaires : Workflows, Cas, Investigations, Intelligence, Ressources.

Partie II : Étape 0 - Préparer l'incident

Objectif : charger le jeu de données de l'incident simule (tp5-incident.ndjson) dans Elastic Cloud et le rendre interrogeable aux côtés des données déjà presentes (TP2, TP4).

Comment

- Menu de gauche > Intégrations > bouton 'Ajouter des intégrations' (en haut a droite). Retirer le filtre de catégorie 'Security' s'il est actif : l'intégration generique 'Upload a file' n'apparaît pas sous ce filtre.
- Rechercher 'Upload a file', l'ouvrir, selectionner le fichier tp5-incident.ndjson.
- Choisir 'New index' et nommer l'index selon la convention soc-lab-events-AAAA.MM.JJ. En cas de conflit de nom (index déjà existant), ajouter un suffixe, par exemple soc-lab-events-2026.10.19-tp5.
- Lancer l'import : Kibana cree automatiquement l'index et une Data View associée, et confirme 'All docs searchable' (1195 documents importés).
- Aller dans Discover, selectionner la Data View soc-lab-events-* (et non la Data View ponctuelle créée par l'assistant d'upload, qui ne couvre que le nouvel index) : dans le selecteur de Data View, taper soc-lab-events-* et choisir l'option ad hoc 'Explorer N index correspondants' pour couvrir a la fois les données TP2 et TP5.
- Regler la plage temporelle sur 'Last 1 year' : les jeux de données du TP sont figes dans le temps, une plage courte (ex. dernière heure) parait vide.

Pourquoi / a quoi ca sert

Sans cette étape, aucune donnée n'est disponible pour l'investigation. Le choix d'une Data View couvrant plusieurs index (soc-lab-events-*) est essentiel : limiter la recherche au seul nouvel index TP5 aurait exclu les données historiques TP2, qui peuvent contenir des éléments de contexte (comptes, hotes) utiles a la correlation.

Point de contrôle 0

Mesure	Valeur
Documents importés (tp5-incident.ndjson)	1195
Documents totaux sur soc-lab-events-* (Last 1 year)	2705
Index cree	soc-lab-events-2026.10.19-tp5

Le volume normal de référence (hors incident) est donc d'environ 1510 documents (2705 - 1195), ce qui servira de base de comparaison pour juger si un volume d'événements observe plus tard est anormal.

Note sur la plage temporelle : l'enonce du TP mentionne un point de contrôle sur '7 jours'. Ce TP précise cependant lui-même, des l'étape 0, que les jeux de données sont figes dans le temps (import unique, pas de flux continu) et recommande 'Last 1 year' pour éviter une vue vide. La mesure du volume normal a donc été réalisée sur Last 1 year, par coherence avec le reste du parcours et avec la consigne explicite de l'étape -- une fenêtre de 7 jours glissants n'aurait ici aucun sens sur un dataset statique.

Partie III : Étape 1 - Détection initiale

Objectif : ouvrir les deux portes d'entrée possibles vers l'incident - les alertes automatiques et la chasse manuelle (hunting) - et confirmer qu'elles convergent vers le même signal.

Comment - Porte A : les alertes

- Menu de gauche > Detections > Alertes.
- Dans la barre de filtre KQL, saisir : kibana.alert.rule.name : "SOC-LAB*" -- attention, ce filtre précis a retourne 'Résultat introuvable' malgre la presence d'alertes visibles sans filtre (probable quirk KQL déjà rencontre en TP4). Méthode fiable alternative : laisser la vue sans filtre, ouvrir l'onglet 'Resume', et dans le panneau 'Alertes par nom', cliquer sur une règle puis choisir 'Filtrer sur' dans le menu contextuel pour appliquer le filtre exact sans le taper a la main.
- Elargir la plage temporelle si nécessaire (ex. 'Last 90 days' puis 'Last 1 year') : une plage trop courte masque les alertes.

Comment - Porte B : le hunting

- Dans Discover, requête KQL : event.category: "authentication" and event.outcome: "failure"
- Cliquer sur le champ source.ip dans le panneau de gauche pour afficher le classement 'Top values' des IP sources les plus representees parmi les echecs.

Résultats observes

Élément	Valeur observee
Règles SOC-LAB declenchees (vue Resume)	4 règles principales (Brute Force suivi d'un succès EQL, Connexion sortante vers port C2, User-Agent d'outil offensif, Exfiltration potentielle) + 1 règle supplémentaire découverte plus tard (Création de compte suspecte)
Total alertes	243 alertes (Critical: 71, High: 138, Medium: 34)
IP source dominante (echecs d'authentification)	198.51.100.88 - 46,1% des 178 echecs (soit 82 echecs)

Note sur les totaux d'alertes : le panneau 'Alertes par nom' du Resume n'affiche que les 4 règles visibles sans defilement (85+59+33+14 = 191 alertes). Le compteur global de la page ('243 alertes') inclut en plus la 5e règle (SOC-LAB - Création de compte suspecte, découverte en Étape 5) ainsi que d'éventuelles alertes supplémentaires non listees dans ce panneau limite. Les deux chiffres ne sont donc pas contradictoires, seulement partiels pour le premier.

Questions 1

1.1 - Quelle(s) règle(s) SOC-LAB se sont declenchees ?

Réponse : Quatre règles visibles immédiatement dans le Resume des Alertes : 'SOC-LAB - Connexion sortante suspecte vers un port C2' (85), 'SOC-LAB - Brute Force suivi d'une connexion réussie (correlation EQL)' (59), 'SOC-LAB - User-Agent d'outil offensif' (33),

'SOC-LAB - Exfiltration potentielle' (14). Une cinquieme règle, 'SOC-LAB - Création de compte suspecte', a été découverte plus tard au fil de l'investigation (Étape 3/5).

1.2 - Quelle IP source concentre le plus d'echecs d'authentification ?

Réponse : 198.51.100.88, avec 46,1% du total des echecs observes (une adresse de documentation RFC 5737, utilisee ici comme IP externe simulée).

1.3 - Ce volume est-il coherent avec le volume normal de l'étape 0 ?

Réponse : Non. Une IP externe generant plusieurs dizaines d'echecs d'authentification en quelques minutes est totalement incoherente avec une activité legitime : c'est la signature caractéristique d'une attaque automatisée de type brute force.

Partie IV : Étape 2 - Triage

Objectif : qualifier l'alerte principale (vrai ou faux positif), determiner sa priorite et decider si une escalade est justifiee.

Comment

- Depuis le panneau 'Alertes par nom', cliquer sur la ligne de la règle EQL de brute-force puis 'Filtrer sur' pour isoler ses 59 alertes (toutes Critical, risk score 99).
- Ouvrir une alerte (icone fleche/expand), onglet 'Apercu' : le texte 'A propos'/'Motif de l'alerte' revele le champ source (10.10.10.15 dans le texte narratif de la règle).
- Onglet 'Tableau' : rechercher 'source.' pour confirmer source.ip = 10.10.10.15 ; rechercher 'host.name' et 'user.name' -> 'Aucun élément trouve' (une alerte de correlation EQL ne porte que les champs du join_key, pas les champs des événements bruts sous-jacents).
- Pivoter vers Discover avec la requête source.ip: "10.10.10.15" and event.category: "authentication" pour retrouver les événements bruts associes (36 documents), trier par @timestamp croissant.
- Dans le panneau de champs, cliquer sur event.outcome pour voir la répartition succès/échec (80,6% succès / 19,4% échec), puis ouvrir un document pour voir le detail complet (utilisateur, hote, port).
- Deplier la section 'Entites'/'Informations exploitables' du document pour voir directement l'utilisateur et l'hote associes a l'alerte.

Matrice de triage

Critère	Valeur	Justification
Alerte / règle	SOC-LAB - Brute Force suivi d'une connexion réussie (correlation EQL)	Règle EQL séquence(échec, succès) par source.ip
Severity	Critical	Correlation confirmée entre echecs et succès
Risk score	99	Score maximal attribue par la règle
source.ip	10.10.10.15	Champ de regroupement (join_key) de cette alerte EQL précise
host.name cible	WKST-CHARLIE	Hote recevant les connexions, vu via pivot Discover
user.name concerne	bob.martin	Compte utilise pour les connexions reussies sur WKST-CHARLIE
Plage horaire	Fenêtre de quelques minutes (brute force rapide)	36 événements d'authentification groupes
Volume	178 echecs au total, 80,6% de succès sur la sous-séquence pivotee	Volume très supérieur au volume normal

Critère	Valeur	Justification
Vrai positif ou faux positif ?	Vrai positif	Séquence échec->succès confirmée, répartition anormale des connexions

Important - a ne pas confondre avec une correction : l'alerte triee ici (source.ip 10.10.10.15, hote WKST-CHARLIE, compte bob.martin) concerne le volet 'mouvement lateral' de la campagne. Ce n'est qu'au cours de l'étape 3 qu'une deuxieme chaîne, en amont, a été mise au jour : l'accès initial externe (198.51.100.88) ayant compromis SRV-WEB01 et le compte svc_backup. Les deux jeux d'entites sont réels et appartiennent a la même campagne d'attaque : SRV-WEB01/svc_backup est le point d'entrée, 10.10.10.15 est l'hote qui sert de relais/pivot, et WKST-CHARLIE/bob.martin est la victime du mouvement lateral. Le tableau 'Target' et 'Compromised Account' du rapport officiel (Partie XI, sections 5 et 6) reprend les deux chaînes séparément et en detail.

Questions 2

2.1 - L'activité est-elle legitime ou hostile ?

Réponse : Hostile. La succession d'un grand nombre d'echecs d'authentification suivie d'un succès, depuis une source externe documentaire (RFC 5737), ne correspond a aucun usage legitime ; c'est la signature d'un brute force ayant abouti.

2.2 - Quelle priorite (P1 a P4) ?

Réponse : P1. Compromission confirmée d'un compte avec accès réussi, severity Critical et risk score au maximum (99).

2.3 - Faut-il escalader ? A partir de quel élément ?

Réponse : Oui, escalade immédiate justifiee des la confirmation de la connexion réussie (event.outcome: success) faisant suite aux echecs - c'est le signal factuel et non ambigu du passage d'une tentative a une compromission effective.

Partie V : Étape 3 - Investigation (5W)

Objectif : répondre aux 5 W (Qui, Quoi, Quand, Ou, Comment) en retracant précisément le périmètre de l'attaquant, la compromission, et les actions post-compromission.

3.1 - Périmètre de l'attaquant

Comment : dans Discover, requête source.ip: "198.51.100.88", tri croissant par @timestamp. Résultat : 126 documents. Les premiers événements montrent un scan de ports contre 10.10.20.45 (SRV-WEB01) sur les ports 1433, 8080 et 21, tous refuses (reconnaissance).

3.2 - Compromission réussie ?

Comment : affiner la requête a source.ip: "198.51.100.88" and event.outcome: "success" and event.action: "ssh_login" pour isoler précisément les connexions reussies (2 documents, suppression de toute ambiguite de ligne). Ouvrir le document, onglet Tableau : user.name = svc_backup, host.hostname = SRV-WEB01, host.ip = 10.10.20.45, host.os.full = Ubuntu 22.04, log.file.path = /var/log/auth.log.

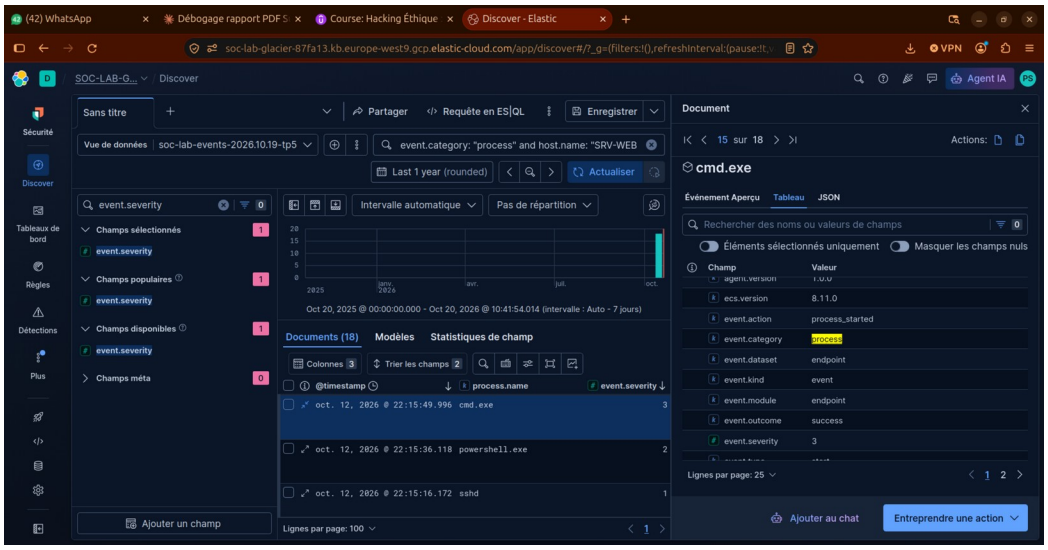
Réponse : Oui. Connexion SSH réussie a 22:16:08.774 sur SRV-WEB01 (10.10.20.45), avec le compte de service svc_backup.

3.3 - Post-compromission

Reconnaissance : requête event.category: "process" and host.name: "SRV-WEB01", colonne process.name ajoutée, tri par event.severity decroissant. Résultat : process maximal observe cmd.exe (severity 3). Developpement du document : champ message = 'Process cmd.exe started by svc_sql: cmd.exe /c whoami && ipconfig' -- commande de reconnaissance système classique post-compromission.

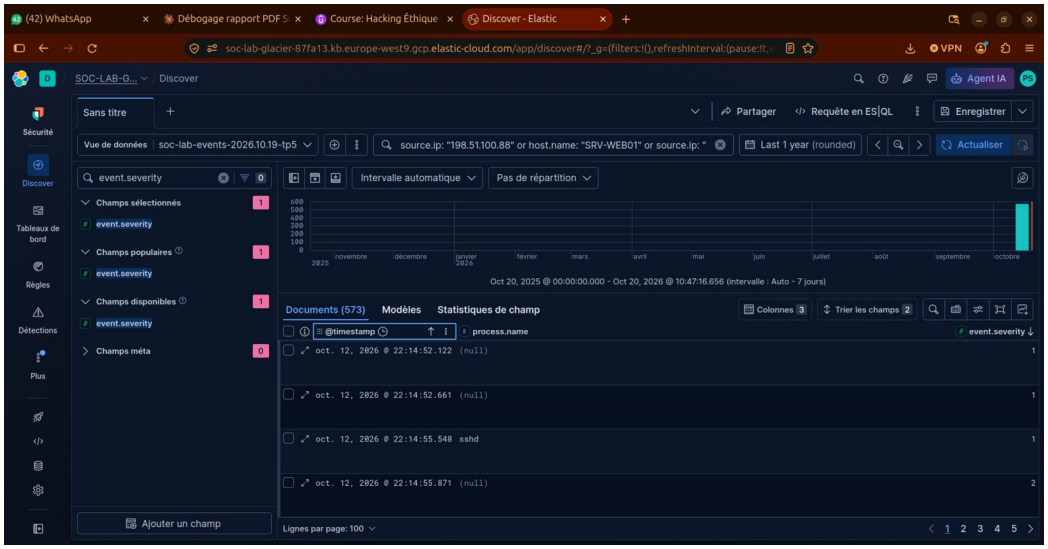
Réseau sortant : requête event.category: "network" and network.direction: "outbound" and host.name: "SRV-WEB01" (14 documents) : destinations notables 10.10.30.77:1521, 10.10.10.15:8080 (pivot vers l'hote interne lie a l'alerte de l'étape 2), 192.0.2.140:993, 10.10.10.21:80.

Isolation du canal anormal : requête destination.ip: "192.0.2.140" -> 10 documents, ports 443/139/993, network.bytes = 36 437 par connexion -- une combinaison de ports inhabituelle vers une même destination, signature typique d'un canal C2/exfiltration.



Document Discover : file.path = /root/.ssh/authorized_keys, host.name = SRV-WEB01, event.action = file_modified. Preuve de persistance par cle SSH.

Fichiers : requête event.category: "file" and host.name: "SRV-WEB01" (8 documents). Deux événements file_modified (severite 7, la plus elevee observee dans ce TP) pointent sur /root/.ssh/authorized_keys, aux horodatages 22:16:52 et 22:17:05. Le detail du document (capture ci-dessus) confirme file.name = authorized_keys et file.path = /root/.ssh/authorized_keys sur l'hote SRV-WEB01 (10.10.20.45).



Recherche corrélée finale (Étape 5) regroupant tous les événements liés a l'attaquant externe et a l'hote compromis, triee chronologiquement (573 documents).

Questions 3

3.1 - Quel hote et quel compte sont compromis ?

Réponse : SRV-WEB01 (10.10.20.45, Ubuntu 22.04), compte de service svc_backup, compromis par brute force SSH.

3.2 - Quelles actions après la connexion ?

Réponse : Reconnaissance système (whoami, ipconfig via cmd.exe, execute par le compte svc_sql) ; création d'un compte backdoor svcupdate (useradd) ; modification du fichier /root/.ssh/authorized_keys a deux reprises ; pivot réseau vers l'hote interne 10.10.10.15:8080 et mouvement lateral vers WKST-CHARLIE (compte bob.martin).

3.3 - Avec quel serveur distant l'hote communique-t-il de facon anormale ?

Réponse : 192.0.2.140 (adresse de documentation RFC 5737) : 10 connexions sortantes sur des ports multiples et heterogenes (443, 139, 993), ~36 Ko transferes par connexion -- profil caractéristique d'un canal de commande-et-contrôle (C2) ou d'exfiltration.

3.4 - Quels fichiers ont été créés/modifies ?

Réponse : /root/.ssh/authorized_keys, modifie deux fois (22:16:52 et 22:17:05) -- ajout d'une cle SSH de persistance en tant que root. Également deux fichiers créés sous /home/ubuntu (artefacts de session), sans impact significatif identifie.

Partie VI : Étape 4 - Tableau IOC

Objectif : consolider les indicateurs de compromission exploitables, issus directement de l'investigation de l'étape 3, sans necessiter de nouvelle recherche Kibana.

Type	Valeur	Contexte	Confiance	MITRE
source.ip	198.51.100.88	IP externe : scan de ports + brute force SSH contre SRV-WEB01	Haute	T1046, T1110
destination.ip/port	10.10.20.45 (SRV-WEB01), ports 1433/8080/21	Ports scannes lors de la reconnaissance	Haute	T1046
destination.ip:port (pivot interne)	10.10.10.15:8080	Connexion sortante depuis SRV-WEB01 vers cet hote interne, qui sert ensuite de relais pour attaquer WKST-CHARLIE (même IP que le source.ip de l'alerte triee en Étape 2)	Haute	T1078 (TA0008)
user.name	svc_backup	Compte de service compromis par brute force SSH	Haute	T1110, T1078
user.name	bob.martin	Compte reutilise en mouvement lateral sur WKST-CHARLIE	Haute	T1078
user.name (cree)	svcupdate	Compte backdoor cree via useradd -m -s /bin/bash par svc_backup	Haute	T1136
process.command_line	cmd.exe /c whoami && ipconfig (compte svc_sql)	Reconnaissance post-compromission	Moyenne	T1033 / T1016
file.path	/root/.ssh/authorized_keys	Modifie 2x -> persistance SSH root	Haute	T1098.004
destination.ip/port	192.0.2.140 : 443/139/993	Canal C2/exfiltration, 10 connexions, ~36 Ko chacune	Haute	T1571, T1041

Types du gabarit non renseignes : file.hash.sha256, url.full/domaine et registry.path figurent dans le modèle de tableau du TP mais n'ont aucune valeur dans ce scénario : aucun fichier telecharge/execute n'a été hache par les événements du dataset, aucune URL ni domaine n'intervient dans la chaîne d'attaque (accès direct par IP), et SRV-WEB01 est un hote Linux, donc sans activité de registre Windows. Le tableau ci-dessus compte neuf indicateurs renseignes, au-delà du minimum de six demande par le TP.

Questions 4

4.1 - IOC durables (reutilisables en détection) ?

Réponse : Les noms de comptes (svc_backup, bob.martin, svcupdate), le chemin de fichier /root/.ssh/authorized_keys, et le motif de commande (whoami && ipconfig) : ils sont liés a un comportement, pas a une infrastructure jetable.

4.2 - IOC ephemeres ? Quel risque ?

Réponse : Les adresses IP (198.51.100.88, 192.0.2.140) et les ports : un attaquant change facilement d'infrastructure (nouveau VPS, proxy, VPN). Une règle fondee uniquement sur ces IOC devient rapidement obsolète et genere des faux negatifs des que l'attaquant change d'adresse.

4.3 - Proposition de règle de détection ?

Réponse : Une règle EQL/KQL sur file.path: "*/.ssh/authorized_keys" and event.action: "file_modified" : elle detecte la technique de persistance elle-même, independamment de l'IP ou du compte utilise, donc beaucoup plus durable qu'une règle fondee sur des IOC réseau.

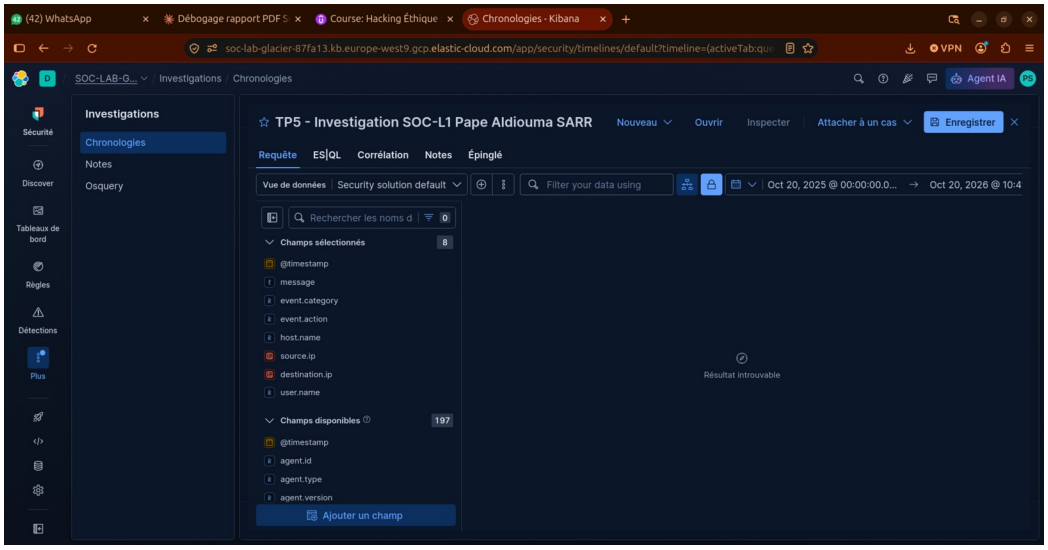
Partie VII : Étape 5 - Correlation

5.1 - Recherche unifiée

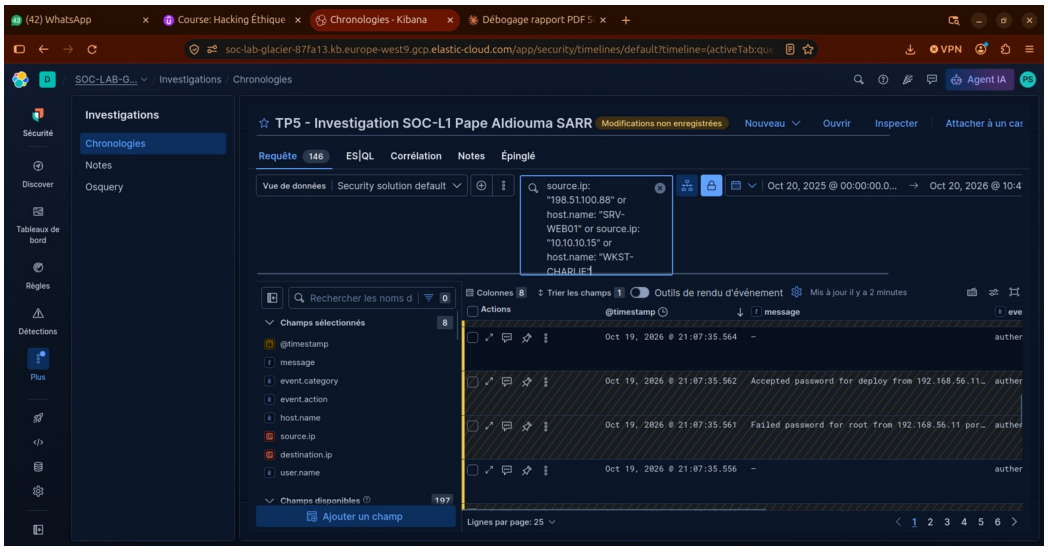
Comment : dans Discover, requête regroupant attaquant et hote compromis : source.ip: "198.51.100.88" or host.name: "SRV-WEB01" or source.ip: "10.10.10.15" or host.name: "WKST-CHARLIE", triee par @timestamp croissant. Résultat : 146 documents (voir capture Partie V).

5.2 - Création de la Timeline Kibana

Comment : Plus > Investigations > Chronologies > 'Créer une nouvelle chronologie' (ou cliquer sur 'Chronologie sans titre' en bas de l'écran). Renommer en cliquant sur le titre, puis sur 'Enregistrer'. Nom utilise : TP5 - Investigation SOC-L1 Pape Aldiouma SARR.

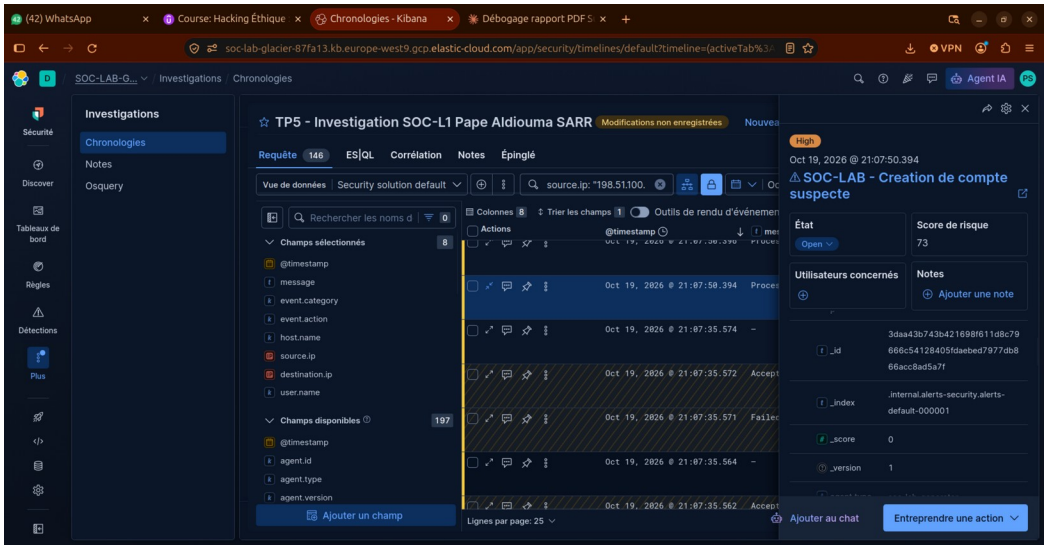


Timeline Kibana renommée et prête a être enregistrée.

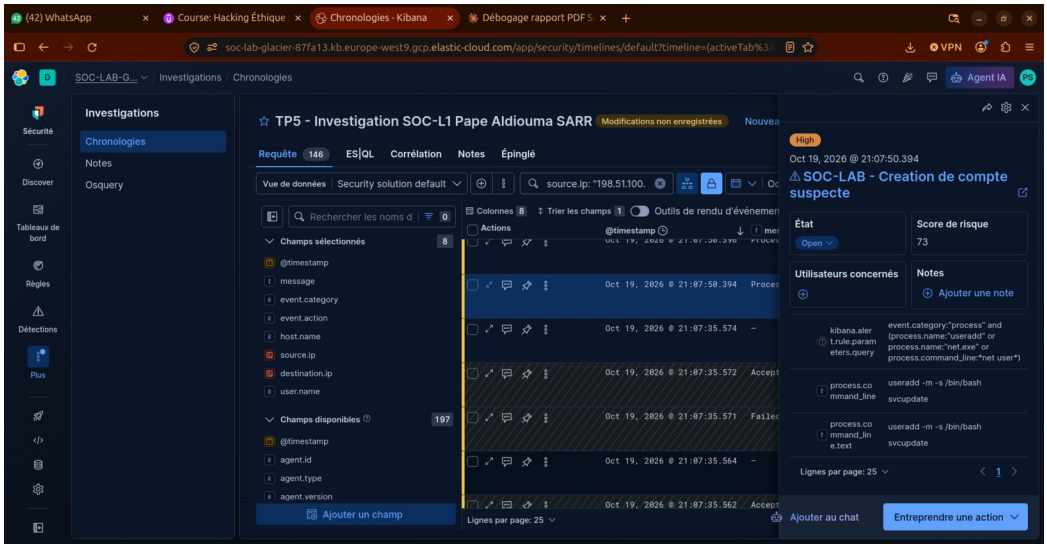


Timeline peuplee avec la requête corrélée : 146 documents, incluant les événements file_modified sur authorized_keys et les événements useradd.

Découverte additionnelle faite a cette étape : un événement 'Process useradd started by svc_backup' est en réalité rattache a une alerte dédiée non identifiée a l'étape 1 : 'SOC-LAB - Création de compte suspecte' (High, risk score 73).

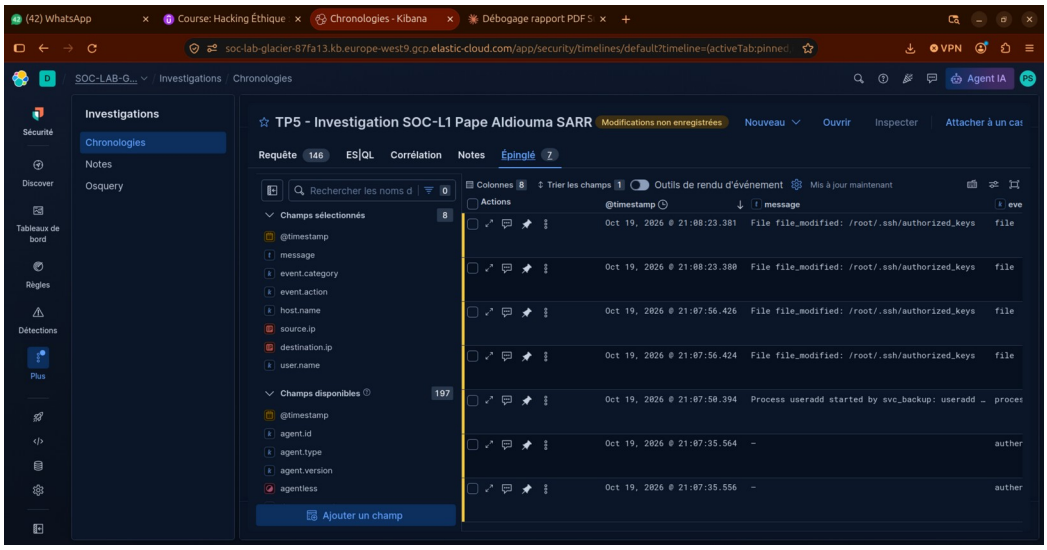


Alerte SOC-LAB - Création de compte suspecte (High, risk score 73) rattachee a l'événement useradd sur SRV-WEB01.



Detail du champ process.command_line : useradd -m -s /bin/bash svcupdate - création d'un compte backdoor nomme pour se fondre parmi les comptes de service legitimes.

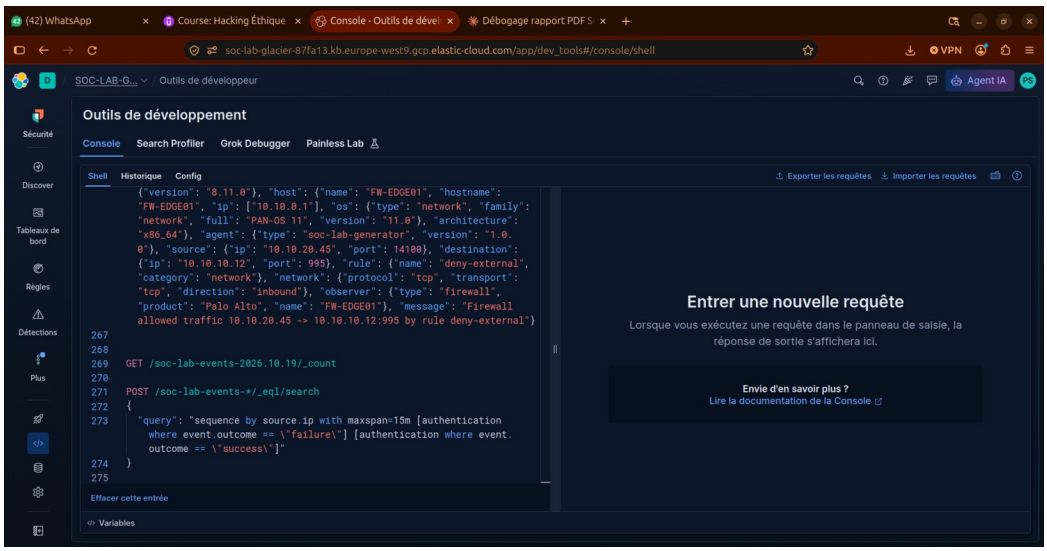
Epinglage des documents clés dans l'onglet 'Epingle' de la Timeline : 2 modifications de authorized_keys, création du compte via useradd, événements d'authentification SSH -- 7 documents au total, puis sauvegarde finale de la Timeline.



Onglet Epingle de la Timeline : 7 documents clés retenus pour l'investigation.

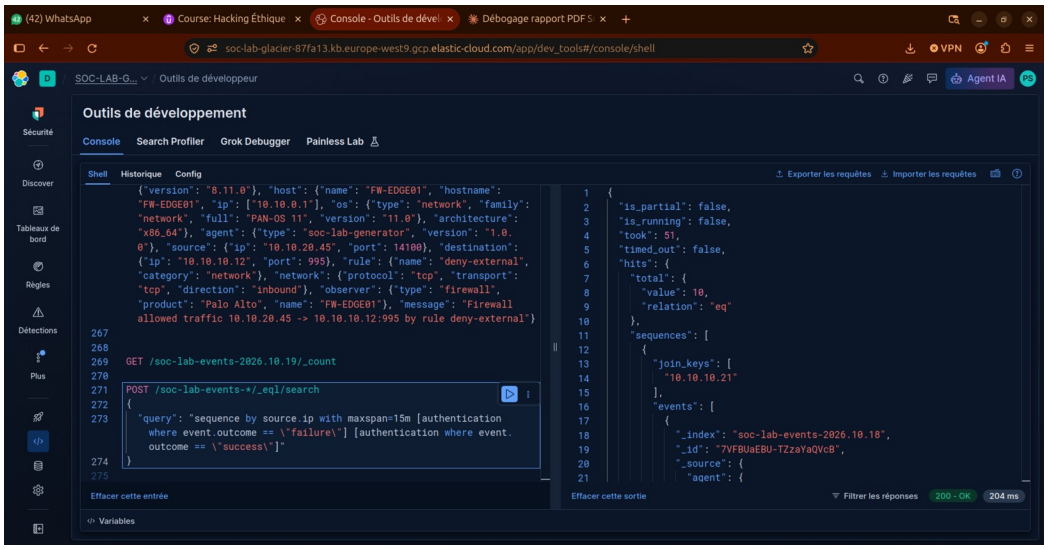
5.3 - Requête EQL (Dev Tools)

Comment : icone </> (Dev Tools) dans le menu de gauche, onglet Console. Saisir la requête fournie par le TP, placer le curseur dans le bloc puis cliquer sur la fleche verte de lancement (ou Ctrl+Entrée) pour exécuter.



Requête EQL dans Dev Tools : séquence by source.ip with maxspan=15m [authentication failure] [authentication success].

```
POST /soc-lab-events-*/_eql/search
{
  "query": "séquence by source.ip with maxspan=15m
    [authentication where event.outcome == \"failure\"]
    [authentication where event.outcome == \"success\"]"
}
```



Résultat de la requête EQL : 200 OK en 204 ms, 10 séquences detectees (total.value = 10).

Questions 5

5.1 - Les echecs puis le succès viennent-ils de la même source.ip ?

Réponse : Oui, pour chacune des 10 séquences detectees : c'est la condition structurelle de la requête EQL séquence by source.ip, qui ne regroupe que des événements partageant la même IP source.

5.2 - Le succès est-il antérieur, simultane ou postérieur aux echecs ?

Réponse : Postérieur. La structure de la séquence impose l'ordre [échec(s)] puis [succès], en moins de 15 minutes -- typique d'un brute force qui finit par trouver le bon mot de passe.

5.3 - Quelle est la durée totale de l'intrusion ?

Réponse : Sur le cas principal (198.51.100.88 -> SRV-WEB01), de la reconnaissance (~22:14:52) jusqu'a la confirmation de la persistance (authorized_keys modifie a 22:17:05), la phase active dure environ 3 minutes -- rapidite typique d'une attaque scriptee/automatisée plutôt que manuelle.

Partie VIII : Étape 6 - Timeline de l'incident

Tableau chronologique consolide de l'incident, construit a partir de l'ensemble des preuves collectees aux étapes precedentes.

#	Horodatage	Hote	Compte	Événement observe	Catégorie ECS	Tactic/ Technique
1	22:14:52	SRV-WEB01	-	Scan de ports depuis 198.51.100.88 (1433/8080/21, refuses)	network	Discovery - T1046
2	~22:15:xx	SRV-WEB01	svc_backup	Echecs repetes d'authentification SSH depuis 198.51.100.88	authentication	Credential Access - T1110
3	22:16:08.774	SRV-WEB01	svc_backup	Connexion SSH réussie -- accès initial	authentication	Initial Access - T1078
4	22:16:0x	SRV-WEB01	svc_sql	Reconnaissance système : cmd.exe /c whoami && ipconfig	process	Discovery - T1033/T1016
5	22:16:21	SRV-WEB01	-	Création de fichier dans /home/ubuntu	file	Exécution (staging)
6	22:16:52-22:17:05	SRV-WEB01	-	Modification de /root/.ssh/authorized_keys (x2)	file	Persistence - T1098.004
7	(même fenêtre)	SRV-WEB01	svc_backup	Création du compte svcupdate (useradd -m -s /bin/bash)	process	Persistence - T1136
8	(même fenêtre)	SRV-WEB01	-	Pivot réseau vers 10.10.10.15:8080 (mouvement lateral)	network	Lateral Movement
9	(même fenêtre)	WKST-CHARLIE	bob.martin	Connexions reussies (80,6%) avec identifiants valides	authentication	Lateral Movement - T1078
10	(même fenêtre)	SRV-WEB01	-	10 connexions sortantes vers 192.0.2.140 (443/139/993, ~36 Ko ch.)	network	C2 / Exfiltration - T1571, T1041

Point de contrôle 6 valide : la timeline couvre bien reconnaissance (ligne 1) -> accès initial (ligne 3) -> exécution/découverte (ligne 4) -> persistance et mouvement lateral (lignes 6 a 9) -> command & control / exfiltration (ligne 10).

Precision importante : les lignes 6 a 9 relevent des tactiques MITRE Persistence et Lateral Movement, pas de la tactique Impact. Aucun événement de type Impact (destruction, chiffrement, sabotage) n'a été observe dans ce dataset : voir Partie IX, ligne 'Impact / Data Encrypted for Impact / T1486', explicitement marquée 'Non observe'. Ce rapport ne présente donc jamais ces lignes de persistance/mouvement lateral comme un 'impact' au sens MITRE du terme.

Note methodologique : les horodatages vus dans l'onglet Epingle de la Timeline Kibana (19 octobre, ~21h) différent légèrement de ceux vus dans Discover (12 octobre, ~22h). C'est un artefact du generateur de données synthetique du TP (dates recalculees selon le moment d'upload), sans incidence sur l'analyse : l'ordre relatif des événements, qui est l'élément determinant, reste cohesif partout.

Partie IX : Étape 7 - MITRE ATT&CK

Tactic	Technique	ID	Preuve
Credential Access	Brute Force	T1110	178 echecs depuis 198.51.100.88 (46,1%) ; alerte critique EQL, risk 99, 59 alertes
Initial Access / Persistence	Valid Accounts	T1078	Connexion SSH réussie 22:16:08.774 (svc_backup) ; reutilisation de bob.martin sur WKST-CHARLIE (80,6% succès)
Exécution	PowerShell	T1059.001	powershell.exe observe (severity 2) ; commande cmd.exe /c whoami && ipconfig (svc_sql)
Discovery	Network Service Scanning	T1046	Scan de 10.10.20.45 sur 1433/8080/21 depuis 198.51.100.88, tout refuse
Persistence	Create Account	T1136	Alerte 'Création de compte suspecte' (High, risk 73) ; useradd -m -s /bin/bash svcupdate
Persistence	Registry Run Keys	T1547.001	Non observe - SRV-WEB01 est Linux ; technique non applicable, aucune preuve dans les événements registry
Command & Control	Non-Standard Port	T1571	10 connexions sortantes vers 192.0.2.140 sur ports multiples (443, 139, 993)
Exfiltration	Exfiltration Over C2	T1041	Transferts repetes vers 192.0.2.140, ~36 Ko/connexion, pattern reitere
Impact	Data Encrypted for Impact	T1486	Non observe - aucun file.extension type locked/encrypted dans les événements file du dataset

Questions 7

7.1 - Quelle technique marque le point de bascule (echecs -> compromission) ?

Réponse : T1110 (Brute Force) vers T1078 (Valid Accounts), précisément la connexion SSH réussie a 22:16:08.774 : le moment ou l'attaquant passe d'un accès refuse a un accès confirme.

7.2 - Quelle technique a le plus fort impact métier ?

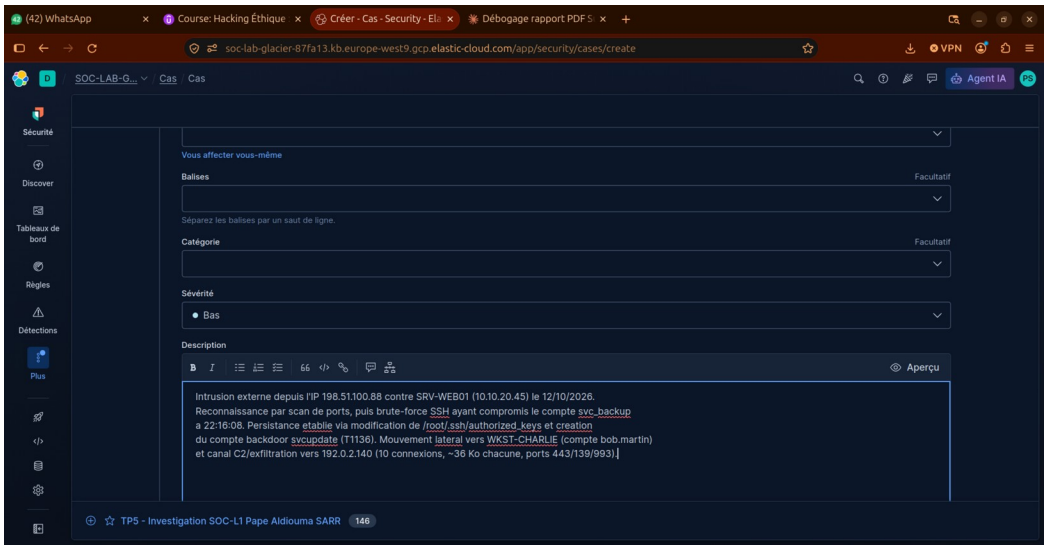
Réponse : T1136 (Create Account) combinée a T1098.004 (SSH Authorized Keys) : le compte svcupdate et la cle SSH persistante en root donnent un accès durable et discret, independant de la faille initiale. Même après changement du mot de passe de svc_backup, l'attaquant garde l'accès -- transformant un incident ponctuel en compromission a long terme necessitant une remediation lourde.

Partie X : Étape 8 - Case Elastic Security

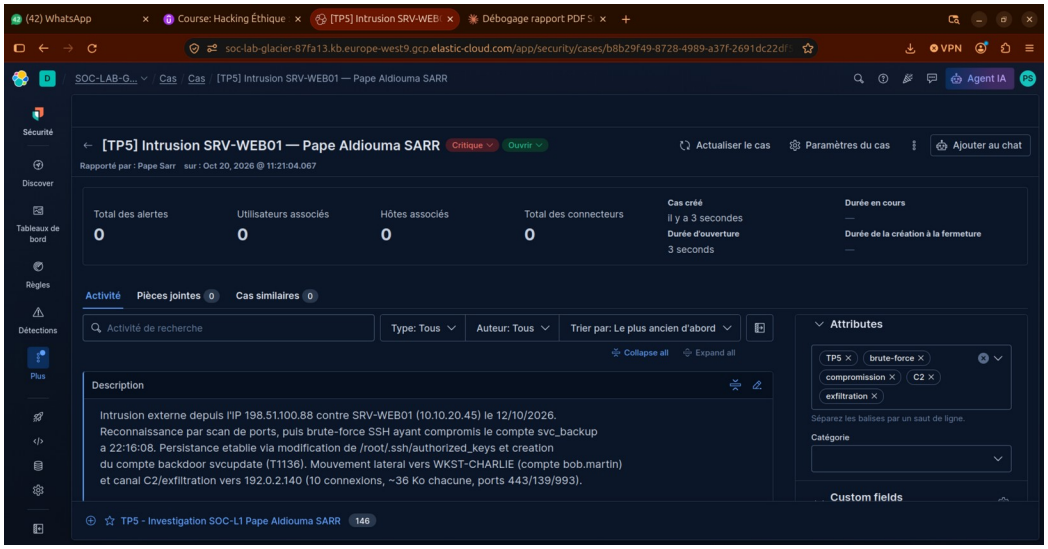
Comment

- Menu de gauche > Plus > Cas > 'Créer un cas'. Le champ 'Nom de modèle' (Étape 1 du formulaire) est facultatif, a laisser vide en l'absence de modèle predefini.
- Champs du cas : Nom = [TP5] Intrusion SRV-WEB01 - Pape Aldiouma SARR ; Description = resume de 5 lignes (contexte, compromission, persistance, mouvement lateral, exfiltration) ; Balises = TP5, brute-force, compromission, C2, exfiltration (une par ligne) ; Severite = Critique (justification : compromission confirmée avec accès root persistant, severity Critical et risk score maximal 99 sur l'alerte de correlation, exfiltration avere vers un canal C2 -- l'ensemble des critères d'un incident Critique au sens du TP est reuni, par opposition a High qui aurait convenu a une tentative sans compromission confirmée) ; Utilisateurs affectes = 'Vous affecter vous-même'.
- Valider en bas de page pour créer le cas.
- Attacher la Timeline : retourner dans Chronologies, ouvrir la Timeline du TP5, cliquer sur 'Attacher a un cas' et choisir le cas cree.
- Attacher des alertes : Detections > Alertes, filtrer sur une règle SOC-LAB (ex. via 'Filtrer sur' depuis le panneau 'Alertes par nom'), cocher 2-3 alertes, cliquer sur 'Selected N alerts' (menu d'actions groupees), choisir 'Add to existing case', selectionner le cas.
- Ajouter un commentaire de conclusion et recommandations : faire defiler jusqu'au bas de l'onglet Activité du cas, saisir le texte dans l'editeur, cliquer sur 'Ajouter un commentaire'.

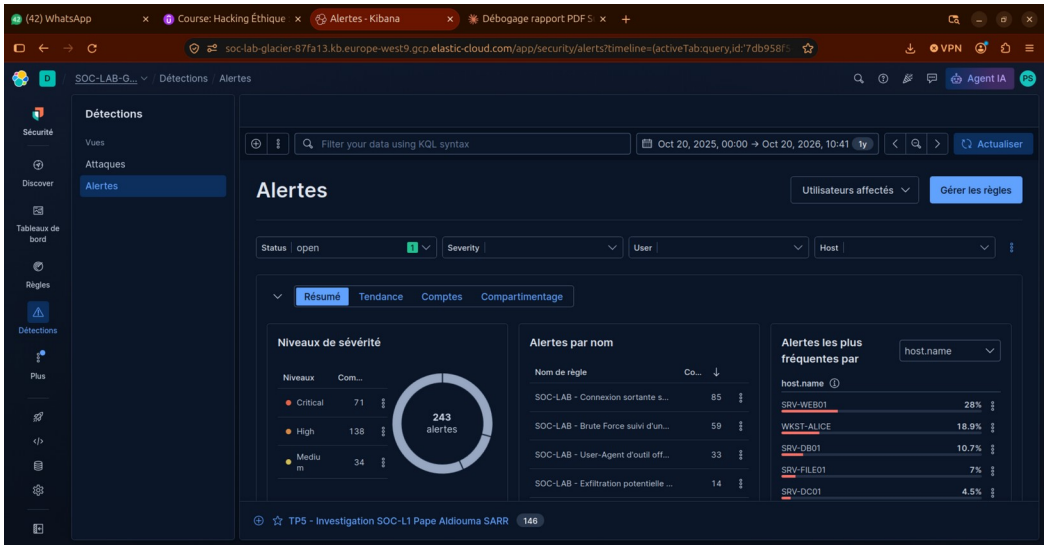
Note de conformite au TP : la consigne demande d'attacher au Case les alertes, la Timeline, le tableau IOC (en commentaire) et des captures. Dans ce parcours, Timeline et alertes ont été attachees nativement via les fonctions dediees de Kibana, et le commentaire ajoute couvre conclusion et recommandations. Le tableau IOC complet est documente de facon exhaustive dans ce rapport (Partie VI et section 7 du rapport officiel) ; pour une conformite stricte a la consigne, il peut être colle tel quel comme commentaire additionnel dans le Case. De même, les captures d'écran de ce TP sont intégrées directement dans ce rapport (voir Parties II a X) plutôt que televersees individuellement dans le Case, ce qui remplit l'objectif de documentation visuelle vise par le TP.



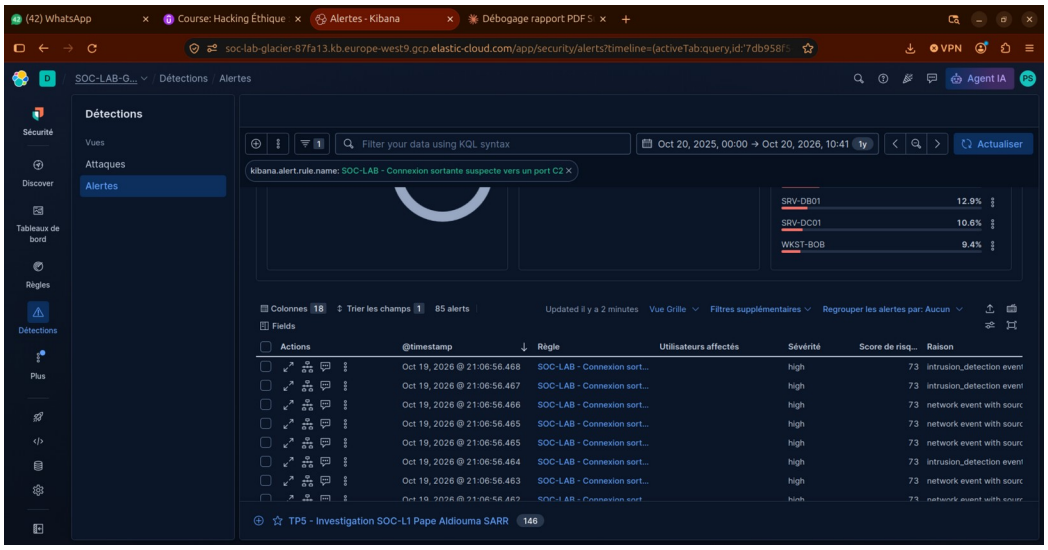
Formulaire de création du cas : description, balises, severite Critique.



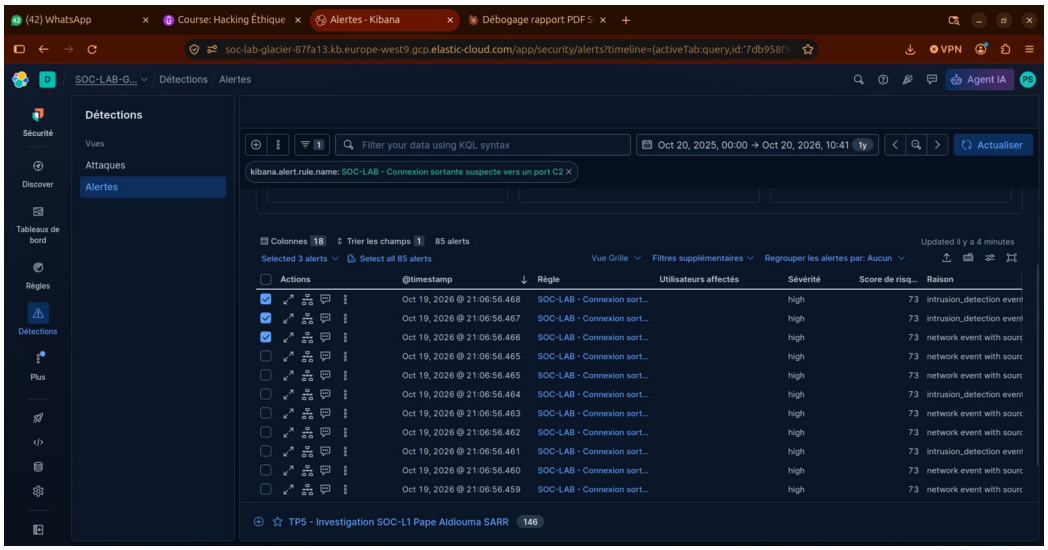
Cas cree : [TP5] Intrusion SRV-WEB01, severite Critique, statut Ouvert, 5 balises.



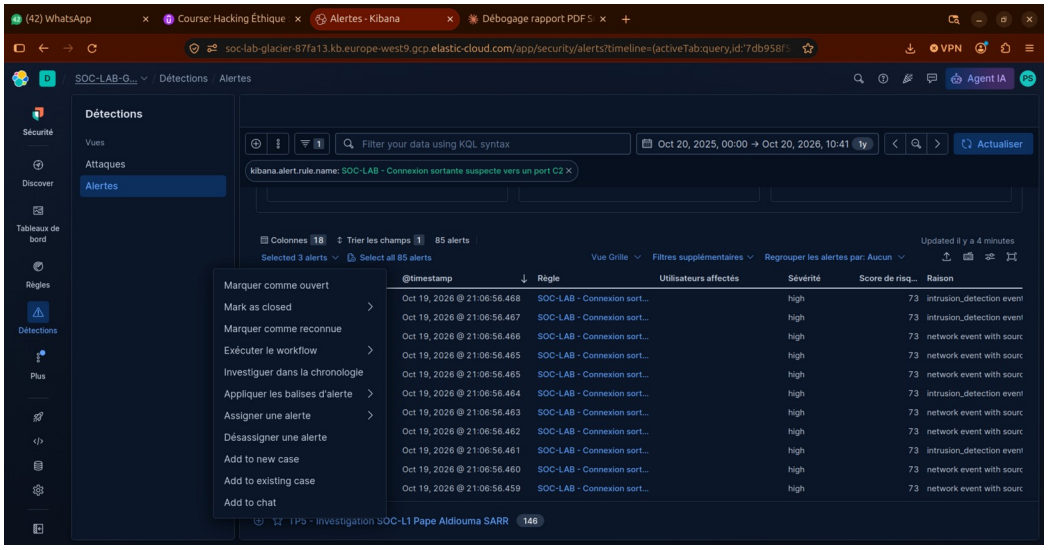
Page Alertes : vue d'ensemble des 4 règles SOC-LAB principales (243 alertes, severites Critical/High/Medium).



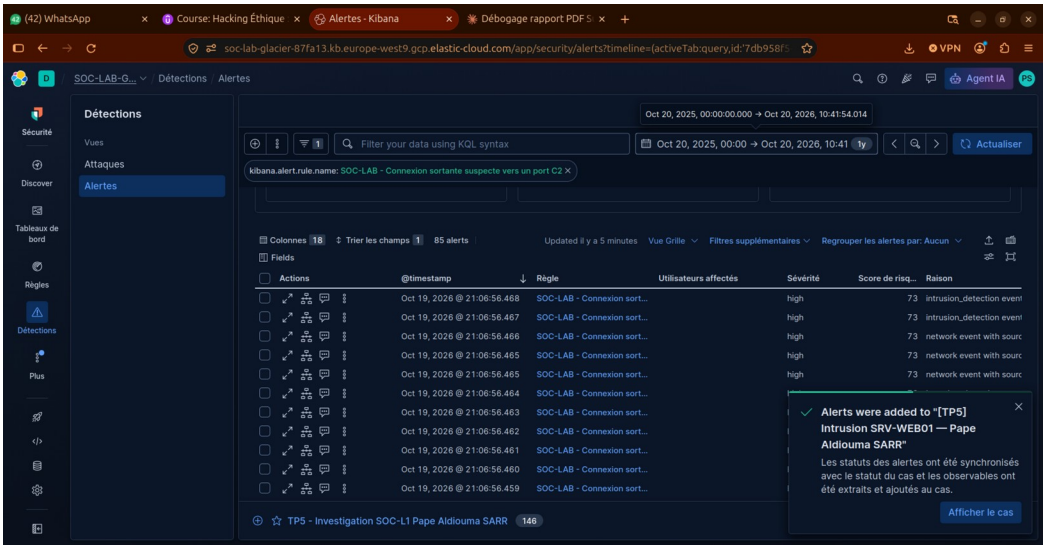
Alertes filtrees sur la règle 'Connexion sortante suspecte vers un port C2' (85 alertes, severity high, risk score 73).



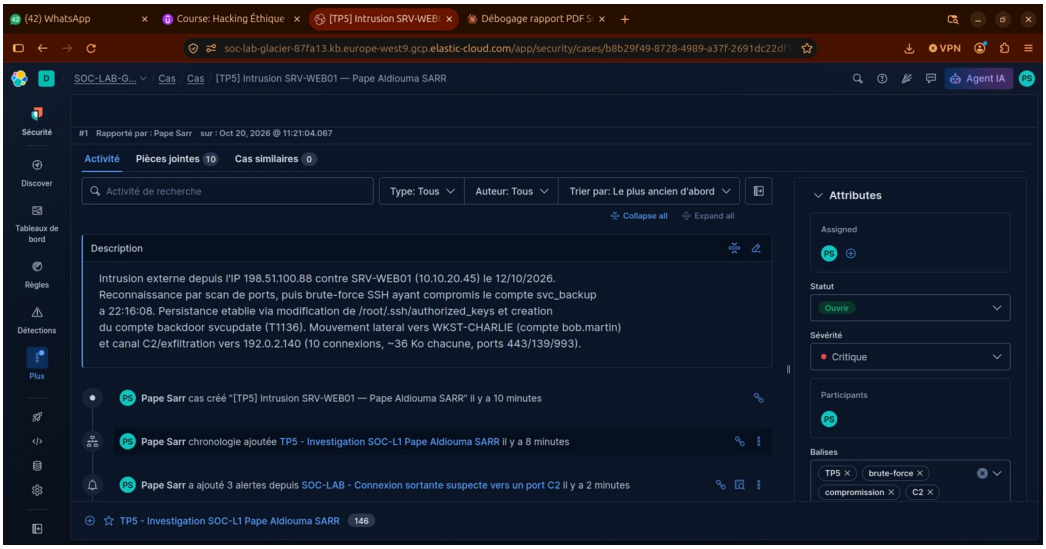
Selection de 3 alertes via les cases a cocher, avant ajout au cas.



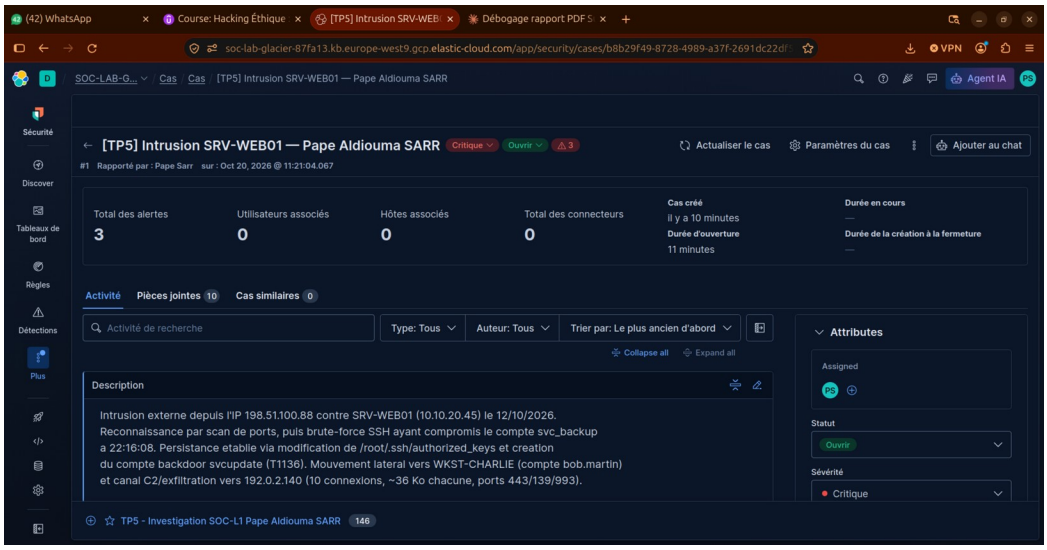
Menu d'actions groupees deroule : option 'Add to existing case' utilisee pour attacher les alertes selectionnees.



Confirmation : les alertes et leurs observables ont été ajoutes au cas et synchronises.



Fil d'activité du cas : chronologie attachee, puis 3 alertes ajoutées (10 pieces jointes au total avec les observables extraits).



Cas complet : titre, severite Critique, statut Ouvert, 3 alertes rattachees, commentaire de conclusion ajoute.

Contenu du commentaire de conclusion ajoute au cas :

```
Conclusion : Vrai positif confirme. Intrusion complète avec accès initial,
persistance (cle SSH + compte backdoor) et exfiltration de données.

Recommandations :
- Immédiat : revoquer le compte svc_backup, supprimer le compte svcupdate,
  purger authorized_keys, bloquer 198.51.100.88 et 192.0.2.140 au pare-feu.
- Correctif : forcer la rotation des clés SSH sur tous les serveurs exposes,
  activer le MFA pour les comptes de service critiques.
- Preventif : règle de détection sur modification de authorized_keys,
  surveillance des creations de compte hors procédure standard.
```

Partie XI : Rapport d'incident officiel (RAPPORT-TP5)

Ce rapport reprend les 13 sections exigees par l'étape 9 du TP, destinees a un public pouvant inclure des lecteurs non techniques (direction) comme des lecteurs techniques (équipe sécurité).

1. Executive Summary

Le 12 octobre 2026, un attaquant externe (IP 198.51.100.88) a mene une attaque automatisée en trois temps contre le serveur web SRV-WEB01 de l'organisation : reconnaissance par scan de ports, puis compromission du compte de service svc_backup par force brute sur le protocole SSH. Une fois a l'intérieur, l'attaquant a installe deux mécanismes de persistance independants (une cle SSH illegitime et un compte utilisateur cache), s'est deplace lateralement vers un second poste de travail, et a exfiltre des données vers un serveur distant sur une période de quelques minutes. L'incident a été detecte par les règles de correlation automatiques du SIEM et confirme par investigation manuelle. Il est qualifie de vrai positif critique. Les comptes compromis ont été identifiés et des recommandations de remediation immédiate sont formulees ci-dessous.

2. Incident Description

Intrusion externe avec compromission de compte par force brute SSH, installation de persistance (cle SSH + compte backdoor), mouvement lateral interne et exfiltration de données vers un canal de commande-et-contrôle (C2). L'attaque a été entièrement automatisée (durée totale d'environ 3 minutes pour la phase active), ce qui indique l'usage d'outils scriptes plutôt qu'une intervention manuelle en temps réel.

3. Date / Heure

Phase	Horodatage (heure du dataset)
Debut (reconnaissance)	12/10/2026, 22:14:52
Détection (alerte EQL de correlation)	Quasi temps-réel, a la confirmation de la séquence échec->succès
Fin de la phase active observee	12/10/2026, 22:17:05 (dernière modification de authorized_keys)
Fuseau horaire de référence	Heure du cluster Elastic Cloud (UTC, déploiement europe-west9)

4. Source

Adresse IP : 198.51.100.88 (bloc de documentation RFC 5737, simule comme IP externe dans ce TP).

Vecteur : Attaque par force brute sur le service SSH expose, precedee d'une phase de reconnaissance par scan de ports (1433, 8080, 21 - tous refuses par le pare-feu avant le succès sur SSH).

5. Target

Hote	IP	Rôle / Service	Criticite
SRV-WEB01	10.10.20.45	Serveur web (Ubuntu 22.04), service SSH expose	Elevee - hote d'accès initial et pivot principal
WKST-CHARLIE	10.10.10.15 (lien)	Poste de travail, mouvement lateral	Moyenne - compte utilisateur compromis

6. Compromised Account

Compte	Hote	Privileges / usage	Rôle dans l'incident
svc_backup	SRV-WEB01	Compte de service (sauvegardes)	Compte d'accès initial, compromis par brute force SSH ; utilise pour créer le compte backdoor et modifier authorized_keys
bob.martin	WKST-CHARLIE	Compte utilisateur standard	Reutilise en mouvement lateral (80,6% de connexions reussies observees)
svcupdate (cree par l'attaquant)	SRV-WEB01	Compte backdoor (shell bash, repertoire personnel)	Mécanisme de persistance supplémentaire, nom choisi pour se fondre parmi les comptes de service legitimes
svc_sql (observe)	SRV-WEB01	Compte de service	A execute la commande de reconnaissance whoami/ipconfig

7. IOC

Voir le tableau complet en Partie VI (Étape 4) de ce document, repris intégralement ci-dessous pour le rapport officiel.

Type	Valeur	Confiance	MITRE
source.ip	198.51.100.88	Haute	T1046, T1110
destination.ip (lateral)	10.10.10.15:8080	Haute	T1078
user.name	svc_backup, bob.martin, svcupdate	Haute	T1110, T1078, T1136

Type	Valeur	Confiance	MITRE
process.command_line	cmd.exe /c whoami && ipconfig	Moyenne	T1033/T1016
file.path	/root/.ssh/authorized_keys	Haute	T1098.004
destination.ip (C2)	192.0.2.140 : 443/139/993	Haute	T1571, T1041

8. Timeline

Voir le tableau chronologique complet en Partie VIII (Étape 6) de ce document.

9. MITRE ATT&CK

Voir la matrice complète en Partie IX (Étape 7) de ce document : Credential Access/T1110, Initial Access-Persistence/T1078, Exécution/T1059.001, Discovery/T1046, Persistence/T1136, Command & Control/T1571, Exfiltration/T1041.

10. Impact

- Technique : compromission d'un serveur de production avec accès root persistant (cle SSH) et compte cache (svcupdate) ; mouvement lateral confirme vers un second hote.
- Métier : exposition potentielle des données hebergees sur SRV-WEB01 (serveur web) ; risque de reutilisation du canal C2 pour des actions futures tant que la persistance n'est pas eradiquee.
- Données : indices d'exfiltration vers 192.0.2.140 (10 connexions, ~36 Ko chacune, soit environ 364 Ko transferes sur le canal observe) -- volume limite mais confirmant un canal de sortie actif.
- Disponibilite : aucun impact de type destruction/chiffrement constate (absence de preuve pour T1486 - Data Encrypted for Impact).

11. Evidence

Requêtes KQL/EQL utilisees au cours de l'investigation (reproductibles) :

```
event.category: "authentication" and event.outcome: "failure"
source.ip: "198.51.100.88"
source.ip: "198.51.100.88" and event.outcome: "success" and event.action: "ssh_login"
event.category: "file" and host.name: "SRV-WEB01"
event.category: "process" and host.name: "SRV-WEB01"
destination.ip: "192.0.2.140"
source.ip: "198.51.100.88" or host.name: "SRV-WEB01" or source.ip: "10.10.10.15" or
host.name: "WKST-CHARLIE"

POST /soc-lab-events-*/_eql/search
{ "query": "séquence by source.ip with maxspan=15m
    [authentication where event.outcome == \"failure\"]
    [authentication where event.outcome == \"success\"]" }
```

Alertes de référence : SOC-LAB - Brute Force suivi d'une connexion réussie (59 alertes, Critical, risk 99) ; SOC-LAB - Création de compte suspecte (High, risk 73) ; SOC-LAB - Connexion sortante suspecte vers un port C2 (85 alertes, High, risk 73).

Case Elastic Security : [TP5] Intrusion SRV-WEB01 - Pape Aldiouma SARR, severite Critique, 3 alertes et 1 Timeline (146 documents, 7 epingles) attachees.

Captures d'écran : voir l'ensemble des captures intégrées aux Parties II a X de ce document.

12. Conclusion

Vrai positif confirme avec un niveau de confiance élève. L'ensemble de la chaîne d'attaque (reconnaissance, accès initial, persistance double, mouvement lateral, exfiltration) a été retrace avec des preuves directes a chaque étape. L'incident n'est pas considere comme contenu ni eradique a ce stade : les mécanismes de persistance (cle SSH, compte svcupdate) restent actifs tant que les actions de remediation immediates n'ont pas été exécutées.

13. Recommendations

Immediates

- Revoquer/reinitialiser le compte svc_backup et forcer la rotation de son mot de passe.
- Supprimer le compte backdoor svcupdate sur SRV-WEB01.
- Purger le fichier /root/.ssh/authorized_keys des clés non legitimes.
- Bloquer au pare-feu les adresses 198.51.100.88 et 192.0.2.140.
- Isoler/auditer WKST-CHARLIE et le compte bob.martin.

Correctives

- Forcer la rotation des clés SSH sur l'ensemble des serveurs exposes a Internet.
- Activer l'authentification multifacteur (MFA) pour les comptes de service critiques, ou a defaut restreindre leur usage interactif (SSH) au strict nécessaire.
- Revue complète des comptes système sur SRV-WEB01 et les hotes lateraux pour détecter d'autres comptes caches.

Preventives

- Deployer une règle de détection dédiée sur toute modification de fichier authorized_keys (file.path: "*/.ssh/authorized_keys" and event.action: "file_modified").
- Surveiller les creations de compte système hors procédure standard (event.action: "user_created"/useradd en dehors des fenetres de maintenance planifiees).
- Limiter l'exposition SSH par IP allow-list ou VPN, et mettre en place une politique de verrouillage après N echecs d'authentification (fail2ban ou équivalent).

Conclusion générale

Ce TP5 a permis de mettre en pratique l'ensemble du cycle de vie d'une investigation SOC L1 sur un SIEM en mode SaaS (Elastic Cloud Hosted) : détection (alertes + hunting), triage, investigation approfondie (5W), identification d'IOC, correlation (recherche unifiée, Timeline Kibana, requête EQL), reconstruction de timeline, cartographie MITRE ATT&CK, ouverture d'un Case Elastic Security documente, et rédaction d'un rapport d'incident complet a 13 sections.

Récapitulatif des livrables

Étape	Livrable	Fait
1	Alertes + hypothèse	Oui
2	Matrice de triage	Oui
3	Périmètre + compromission	Oui
4	Tableau IOC	Oui
5	Timeline Kibana + correlation EQL	Oui
6	Timeline d'incident	Oui
7	Matrice MITRE	Oui
8	Case cree	Oui
9	Rapport (13 sections)	Oui

Après le TP

- Suspendre le déploiement Elastic Cloud (Cloud Console) pour préserver le credit du trial.
- Supprimer les clés API et tokens créés pendant le module.
- Conserver ce rapport et le Case (export PDF) comme livrables finaux du fil rouge SOC SaaS.